

API Security Risk Analysis

Report

Target: Public Sample APIs (test/demo)

Date: 20 May 2026

Prepared by: Maramakshaya

Report Details

Author	Maramakshaya
Date	20 May 2026
Task	Task 3 — API Security Risk Analysis
GitHub	FUTURE_CS_03

Scope

APIs Tested	3 Public APIs
Tool	Postman (Web)
Method	GET Request + Header Analysis
Deadline	10/06/2026

Executive summary

This report presents an API Security Risk Analysis conducted on three public sample APIs using Postman Web. The analysis identified critical security vulnerabilities including missing authentication, sensitive data exposure, missing security headers, and IP address leakage. All findings are documented with evidence screenshots and remediation recommendations.

Risk summary



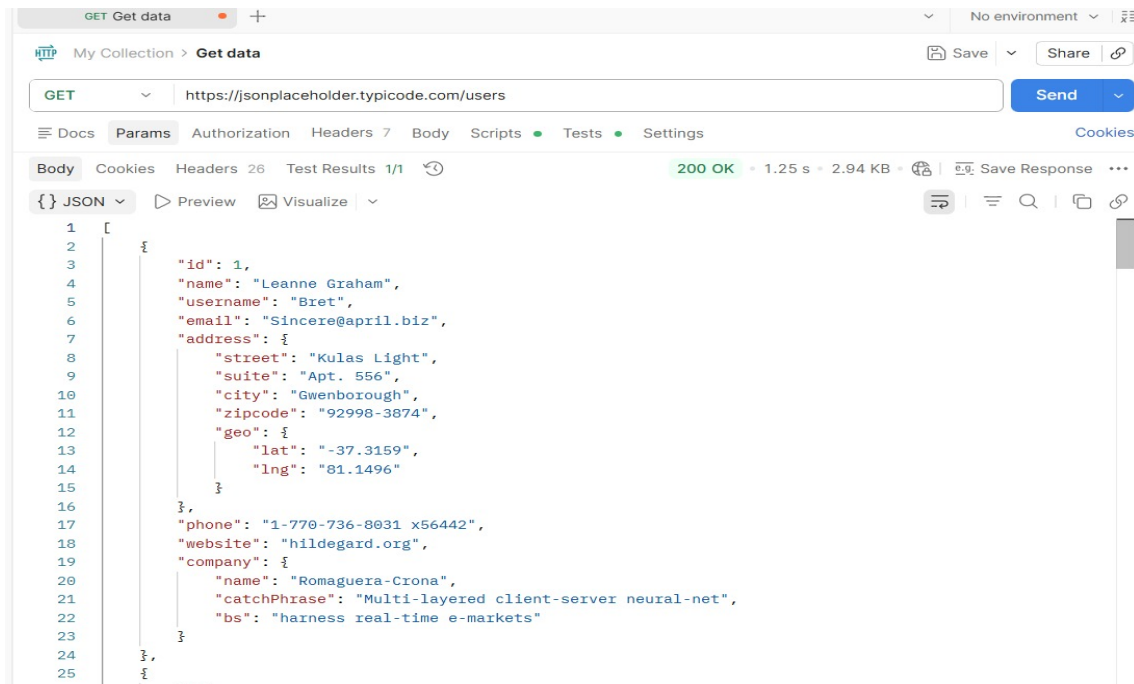
APIs tested

API 1	jsonplaceholder.typicode.com/users	User data exposure
API 2	reqres.in/api/users	PII data exposure
API 3	httpbin.org/get	Header & IP leakage

SECTION 2

API 1 — JSONPlaceholder users endpoint

Postman screenshot — Response Body



GET Get data

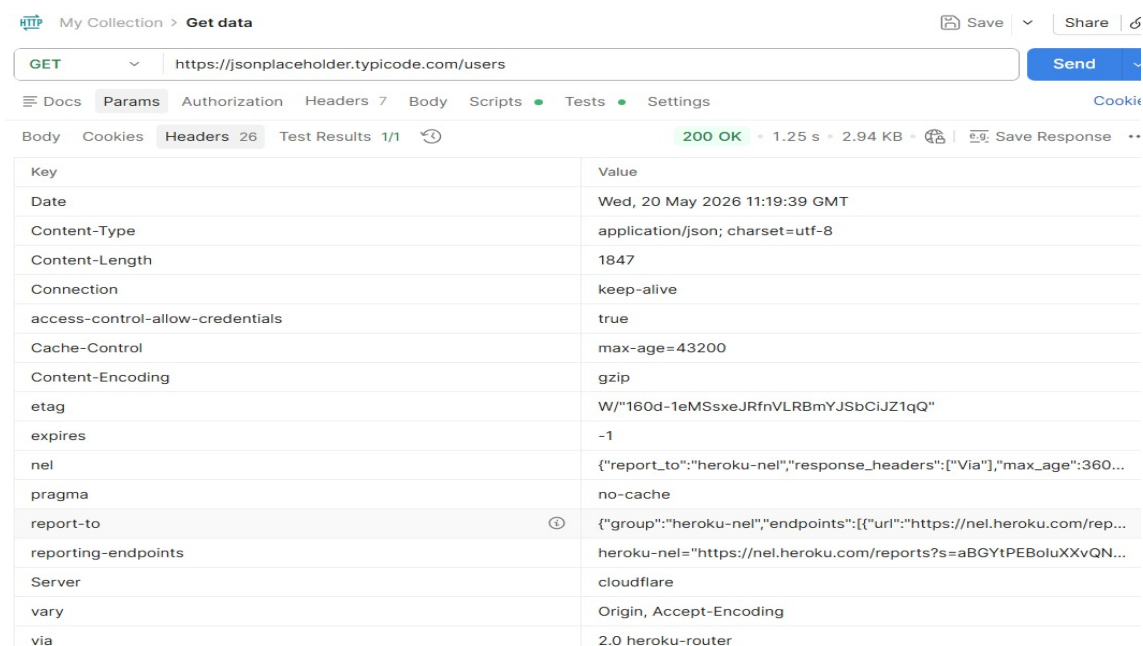
My Collection > Get data

GET https://jsonplaceholder.typicode.com/users

200 OK • 1.25 s • 2.94 KB

```
{
  "id": 1,
  "name": "Leanne Graham",
  "username": "Bret",
  "email": "Sincere@april.biz",
  "address": {
    "street": "Kulas Light",
    "suite": "Apt. 556",
    "city": "Gwenborough",
    "zipcode": "92998-3874",
    "geo": {
      "lat": "-37.3159",
      "lng": "81.1496"
    }
  },
  "phone": "1-770-736-8031 x56442",
  "website": "hildegard.org",
  "company": {
    "name": "Romaguera-Crona",
    "catchPhrase": "Multi-layered client-server neural-net",
    "bs": "harness real-time e-markets"
  }
}
```

Postman screenshot — Response Headers



GET https://jsonplaceholder.typicode.com/users

200 OK • 1.25 s • 2.94 KB

Key	Value
Date	Wed, 20 May 2026 11:19:39 GMT
Content-Type	application/json; charset=utf-8
Content-Length	1847
Connection	keep-alive
access-control-allow-credentials	true
Cache-Control	max-age=43200
Content-Encoding	gzip
etag	W/"160d-1eMSsxeJRfnVLRBmYJSbCiJZ1qQ"
expires	-1
nel	{"report_to": "heroku-nel", "response_headers": [{"uri": "https://nel.heroku.com/rep...
pragma	no-cache
report-to	{"group": "heroku-nel", "endpoints": [{"uri": "https://nel.heroku.com/rep...
reporting-endpoints	heroku-nel="https://nel.heroku.com/reports?s=aBGYtPEBoluXXvQN...
Server	cloudflare
vary	Origin, Accept-Encoding
via	2.0 heroku-router

Security findings

Finding	Details	Risk
No Authentication	API returns full user data without any login or API key	■ High
PII Data Exposed	Name, email, phone, address, GPS coordinates visible	■ High
No Rate Limiting	Unlimited requests allowed — open to scraping attacks	■ High
Server Disclosed	Server: cloudflare revealed in response headers	■ Medium
No CSP Header	Content-Security-Policy header missing from response	■ Medium

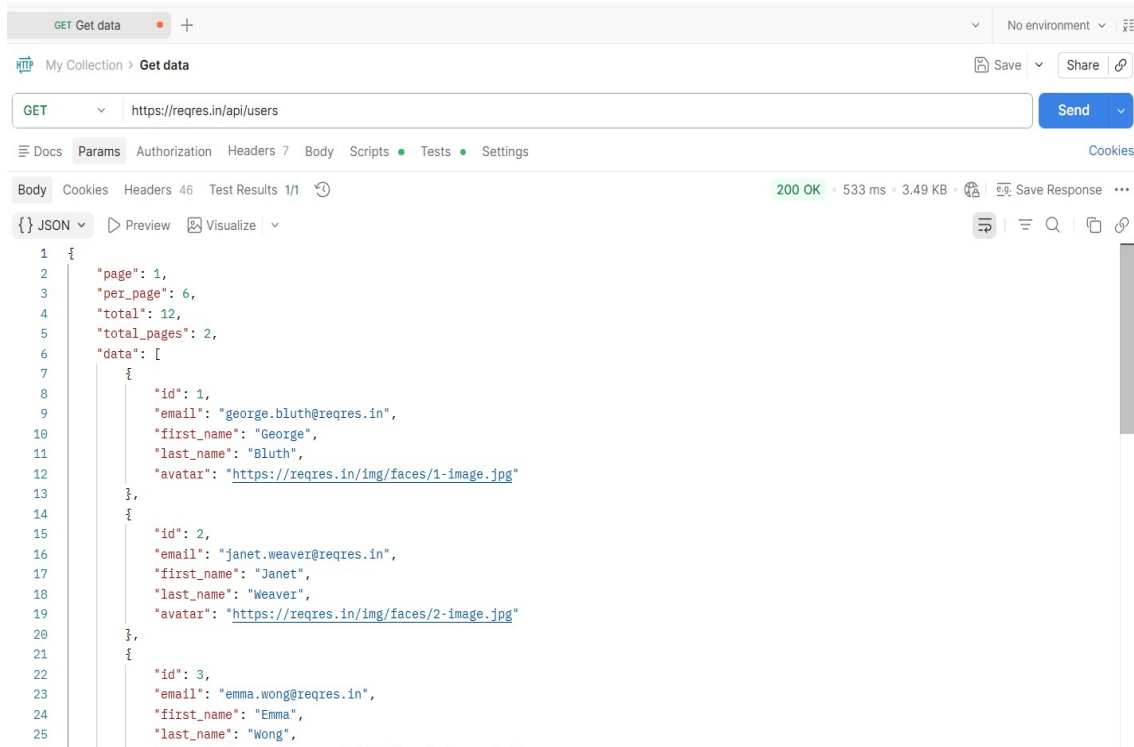
Exposed sensitive data:

- Full name — Leanne Graham
- Username — Bret
- Email — Sincere@april.biz
- Phone — 1-770-736-8031 x56442
- Full street address + zipcode
- GPS coordinates — lat: -37.3159, lng: 81.1496
- Company name and details

SECTION 3

API 2 — ReqRes users endpoint

Postman screenshot — Response Body



Security findings

Finding	Details	Risk
No Authentication	Email and personal data returned without login	■ High
Email Exposed	george.bluth@reqres.in, janet.weaver@reqres.in visible	■ High
Total Count Exposed	Total user count (12) and pages (2) revealed	■ Medium
Avatar URLs Exposed	Direct image URLs accessible without authentication	■ Low

SECTION 4

API 3 — HTTPBin headers endpoint

Postman screenshot — Response Body

The screenshot shows a Postman interface with a GET request to `https://httpbin.org/get`. The response status is 200 OK, with a response time of 414 ms and a body size of 676 B. The response body is displayed in JSON format, showing a list of headers and other metadata.

```
1 {
2   "args": {},
3   "headers": {
4     "Accept": "*/*",
5     "Accept-Encoding": "gzip, deflate, br",
6     "Cache-Control": "no-cache",
7     "Host": "httpbin.org",
8     "Postman-Token": "81f0406a-747e-4836-97aa-86973917b18b",
9     "User-Agent": "PostmanRuntime/7.54.0",
10    "X-Amzn-Trace-Id": "Root=1-6a0d9bbc-0e3f73d80fb4eea523d403cd"
11  },
12  "origin": "2409:40f0:11d4:6cd4:6440:47eb:7488:96c7, 54.86.50.139",
13  "url": "https://httpbin.org/get"
14 }
15
```

Security findings

Finding	Details	Risk
IP Address Leaked	Full IPv6 address: 2409:40f0:11d4:6cd4... exposed in response	■ High
Token Exposed	Postman-Token: 81f0406a-747e-4836-97aa... visible	■ Medium
Client Info Exposed	User-Agent: PostmanRuntime/7.54.0 reveals client tool	■ Medium
Trace ID Exposed	X-Amzn-Trace-Id reveals internal AWS infrastructure	■ Low
No Authentication	All request headers returned freely without any auth	■ High

SECTION 5

API security risks summary

Complete risk findings across all APIs

#	Risk	API Affected	Impact	Remediation
1	No Authentication	All 3 APIs	Anyone can access data	Implement API keys or OAuth 2.0
2	PII Data Exposure	API 1, API 2	Privacy violation, GDPR breach	Mask sensitive fields, use authorization
3	IP Address Leakage	API 3	User location/identity exposed	Strip IP from responses, use proxy
4	No Rate Limiting	All 3 APIs	DDoS, data scraping attacks	Implement rate limiting per IP/token
5	Missing Security Headers	API 1	XSS, clickjacking attacks possible	Add CSP, X-Frame-Options headers
6	Server Info Disclosed	API 1	Aids targeted attacks	Remove Server header from responses
7	Token in Response	API 3	Token replay attacks possible	Never return tokens in response body

Recommendations and conclusion

The API security analysis revealed significant vulnerabilities across all three public APIs. The most critical issue is the complete absence of authentication, allowing anyone to access sensitive user data. The following recommendations should be implemented immediately:

Immediate actions — High risk

Implement Authentication	Use API keys, JWT tokens, or OAuth 2.0 to restrict access to authorized users only. No API should return user data without verifying the caller identity.
Remove PII from Responses	Never expose full names, emails, phone numbers, GPS coordinates, or addresses in unauthenticated API responses. Mask or remove sensitive fields.
Add Rate Limiting	Restrict each IP to a maximum number of requests per minute to prevent automated scraping and DDoS attacks.
Strip IP from Responses	Never return the caller's IP address in API responses as it exposes user location and identity.

Short term actions — Medium/Low risk

Add Security Headers	Add Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options headers to all API responses.
Hide Server Information	Remove or mask the Server response header to prevent disclosure of backend infrastructure.
Remove Internal Tokens	Never include internal tokens, trace IDs, or session identifiers in API responses.
Input Validation	Validate and sanitize all input parameters to prevent injection attacks.

Prepared by	Maramakshaya
Date	20 May 2026
Tool	Postman Web Browser DevTools
APIs Tested	jsonplaceholder.typicode.com reqres.in httpbin.org